

Vault Cluster Infrastructure Pentest — Checklist + Commands (8 Hosts)

Companion to `vault_pentest_checklist.md` and `vault_pentest_commands.md`. This covers the **host/network layer** underneath Vault, not the Vault API/policy layer.

Set up target list first:

```
bash
cat > vault_hosts.txt << EOF
10.0.1.11
10.0.1.12
10.0.1.13
10.0.1.14
10.0.1.15
10.0.1.16
10.0.1.17
10.0.1.18
EOF
mkdir -p scans vault_pentest_evidence
```

1. Host Discovery

- ☐ Confirm all 8 hosts respond / are alive
- ☐ Confirm no unexpected 9th host is answering on the same subnet (shadow node)

```
bash
nmap -sn -iL vault_hosts.txt -oA scans/host_discovery

# If ICMP is blocked, fall back to TCP ping on common ports
nmap -sn -PS22,80,443,8200 -iL vault_hosts.txt -oA scans/host_discovery_tcp
```

2. Full Port Sweep (per host)

- ☐ Full TCP port range scanned on every host
- ☐ Every open port identified with service/version
- ☐ Any port not explicitly documented in the architecture diagram flagged for follow-up

```
bash
```

```
nmap -sS -p- -T4 -iL vault_hosts.txt -oA scans/full_tcp
```

```
nmap -sV -sC -p- -iL vault_hosts.txt -oA scans/full_tcp_sv
```

3. UDP Sweep

- ☐ UDP scan run (often skipped, but Consul gossip and DNS live here)



```
bash
```

```
nmap -sU --top-ports 200 -iL vault_hosts.txt -oA scans/udp_top200
```

```
# Targeted UDP ports relevant to Consul/DNS
```

```
nmap -sU -p 53,8301,8302,8600 -iL vault_hosts.txt -oA scans/udp_targeted
```

4. Vault-Specific Ports

- ☐ Port 8200 (API) reachability mapped per host — internal vs external
- ☐ Port 8201 (cluster/replication) confirmed **not** reachable from outside the cluster network
- ☐ Confirm which host(s) are active leader vs standby



```
bash
```

```
nmap -sV -p 8200,8201 -iL vault_hosts.txt -oA scans/vault_ports
```

```
# Per-host leader check via API (unauthenticated)
```

```
for host in $(cat vault_hosts.txt); do
```

```
echo "=== $host ==="
```

```
curl -sk "https://$host:8200/v1/sys/health" | jq '.standby, .performance_standby, .replication_dr_mode'
```

```
done
```

```
# Confirm cluster port is not internet-reachable from your test position
```

```
nmap -p 8201 -iL vault_hosts.txt --reason
```

5. Storage Backend Ports (Consul, if applicable)

- ☐ Consul HTTP API (8500) not exposed without ACL enforcement
- ☐ Consul RPC (8300) restricted to cluster members only
- ☐ Consul Serf gossip (8301 TCP/UDP LAN, 8302 TCP/UDP WAN) restricted
- ☐ Consul DNS (8600) not resolvable from untrusted networks



```
bash
```

```
nmap -sV -p 8300,8301,8302,8500,8600 -iL vault_hosts.txt -oA scans/consul_ports
```

```
# Test unauthenticated Consul KV read (should fail if ACLs enforced)
```

```
for host in $(cat vault_hosts.txt); do
  echo "=== $host ==="
  curl -sk "http://$host:8500/v1/kv/vault/?recurse" -o /dev/null -w "%{http_code}\n"
done
```

```
# Test unauthenticated Consul catalog enumeration
```

```
curl -sk http://<consul-host>:8500/v1/catalog/services
```

6. Raft Integrated Storage (if not using Consul)

☐ No additional management port exposed beyond 8200/8201

☐ Confirm no direct filesystem/network access path to the `data` directory from other hosts

```
bash
# From an authenticated Vault session
vault operator raft list-peers
vault read sys/storage/raft/configuration
```

7. TLS Configuration Per Host

☐ Valid cert on every host (not expired, correct SANs, trusted CA if internal PKI)

☐ No weak ciphers / protocol versions accepted

☐ Cert not shared improperly across unrelated services

```
bash
for host in $(cat vault_hosts.txt); do
  echo "=== $host ==="
  nmap --script ssl-enum-ciphers,ssl-cert -p 8200 "$host"
done

# Manual cert inspection
for host in $(cat vault_hosts.txt); do
  echo "=== $host ==="
  echo | openssl s_client -connect "$host:8200" 2>/dev/null | openssl x509 -noout -dates -subject -issuer -ext s
done
```

8. Other Infra Services Bolted onto These Hosts

- ☐ SSH exposed only where intended, key-based auth enforced, root login disabled
- ☐ Monitoring agents (node_exporter, Prometheus, Grafana) not exposed without auth
- ☐ Any log shipping agents (Filebeat, Fluentd) not leaking to unauthenticated collectors
- ☐ No orphaned/forgotten services (old admin panels, default installs)

```
bash
nmap -sV -p 22,161,9100,9090,3000,5601,9200,9300 -iL vault_hosts.txt -oA scans/infra_extras

# node_exporter/Prometheus metrics often unauthenticated by default — check exposure
for host in $(cat vault_hosts.txt); do
  echo "=== $host ==="
  curl -sk "http://$host:9100/metrics" -o /dev/null -w "%{http_code}\n"
  curl -sk "http://$host:9090/api/v1/status/config" -o /dev/null -w "%{http_code}\n"
done

# SSH config check (once you have shell access to any host)
ssh -T | grep -iE "permitrootlogin|passwordauthentication|pubkeyauthentication"
```

9. Network Segmentation Validation

- ☐ Confirm application/DMZ segment can only reach 8200 (not 8201, not Consul ports, not SSH)
- ☐ Confirm inter-node cluster traffic (8201, Consul gossip) is restricted to the cluster subnet only
- ☐ Confirm no lateral path from a compromised app-tier host directly to storage backend, bypassing Vault's barrier

```
bash

# Run from a lower-trust network segment (coordinate placement with client)
nmap -p 8200,8201,8300,8301,8302,8500,8600 -iL vault_hosts.txt -oA scans/segmentation_test

# Firewall/ACL evidence — compare open ports seen from different network vantage points
diff scans/segmentation_test.gnmap scans/vault_ports.gnmap
```

10. Host-Level Hardening (requires shell/SSH access to hosts)

- ☐ OS patch level current
- ☐ Vault binary integrity verified against official checksum
- ☐ Vault config file (`[vault.hcl]`) permissions restricted (not world-readable)
- ☐ No unseal keys / root tokens in shell history, cron, or config management artifacts
- ☐ Vault systemd service hardened (non-root user, `[NoNewPrivileges]`, `[ProtectSystem]`)

- ☐ `mlock` enabled / swap disabled to prevent secrets paging to disk
- ☐ Core dumps disabled for the Vault process



bash

Run per host via SSH

```
for host in $(cat vault_hosts.txt); do
```

```
echo "=== $host ==="
```

```
ssh "$host" 'cat /etc/os-release; uname -r'
```

```
done
```

Binary integrity

```
ssh <host> 'sha256sum $(which vault)'
```

Compare against: <https://releases.hashicorp.com/vault/<version>/vault-<version>-SHA256SUMS>

Config file permissions

```
ssh <host> 'ls -la /etc/vault.d/vault.hcl'
```

Search for leaked secrets in common locations

```
ssh <host> 'grep -riE "unseal|root.?token" /root/.bash_history /home/*/.bash_history 2>/dev/null'
```

```
ssh <host> 'find / -iname "*.tfstate" -o -iname "*.retry" 2>/dev/null | xargs grep -l "vault" 2>/dev/null'
```

systemd hardening check

```
ssh <host> 'systemctl cat vault.service'
```

mlock / swap check

```
ssh <host> 'cat /etc/vault.d/vault.hcl | grep -i mlock'
```

```
ssh <host> 'getcap $(which vault)' # expect cap_ipc_lock+ep
```

```
ssh <host> 'swapon --show; free -h'
```

Core dump check

```
ssh <host> 'ulimit -c; cat /proc/sys/kernel/core_pattern'
```

11. Cluster Consensus / Split-Brain Check

- ☐ All 8 hosts confirmed as legitimate members of the same Raft/Consul cluster
- ☐ No standalone or stale node holding outdated data
- ☐ Leader election behaves correctly under simulated failure (only if authorized for HA/DR testing)



bash

```
vault operator raft list-peers
vault read sys/storage/raft/configuration
```

Cross-check peer list against your 8-host inventory — any mismatch is a finding

12. Evidence Collection




```
bash
mkdir -p vault_pentest_evidence/infra
cp scans/*.nmap scans/*.gnmap vault_pentest_evidence/infra/
for host in $(cat vault_hosts.txt); do
  curl -sk "https://$host:8200/v1/sys/health" > "vault_pentest_evidence/infra/health_$host.json"
done
```

Suggested order of operations

§1–4 unauthenticated, from outside the cluster network (external view)

§5–6 to map the storage backend's independent exposure

§7–9 to validate segmentation and TLS posture

§10–11 once you have host or Vault API credentials (insider view)

§12 throughout, to keep evidence organized as you go